

SPP Compliance Layer

Capturar capital institucional para a Stellar

fechando o trilema privacidade × compliance × durabilidade quântica

Manuel Galmanus · 07 de agosto de 2026

Sumário executivo

Capital institucional não entra em blockchain pública por três razões que se bloqueiam mutuamente. Uma tesouraria não pode expor posições e contrapartes (**privacidade**); um regulador não aceita privacidade sem allow-list e trilha de auditoria (**compliance**); e nenhum dos dois aceita que a prova de compliance se apoie em criptografia que um computador quântico vai quebrar num livro-razão permanente (**durabilidade**). A Stellar já resolveu a primeira perna, com os primitivos de pagamento privado da Nethermind e o Confidential Token da OpenZeppelin. As duas outras estão abertas — e são exatamente onde o **SPP Compliance Layer** atua.

Tese. O SPP Compliance Layer transforma a privacidade que a Stellar já tem no produto que uma instituição pode de fato usar: uma política de compliance provada honesta por criptografia **pós-quântica** e imposta **on-chain**. Com isso, remove o bloqueador que hoje mantém tesourarias, custodiantes e emissores de RWA fora da rede.

O ponto não é “mais uma prova de conhecimento zero”. Os primitivos de privacidade da Stellar hoje provam com *pairing* sobre BN254 (Groth16, UltraHonk), e a própria SDF afirma, no Quantum Preparedness Plan: “*there is no drop-in post-quantum replacement for pairing-based SNARKs.*” Uma atestação de compliance construída sobre essa curva pode, com o tempo, ser **forjada**. O SPP Compliance Layer atesta a parte que se pode tornar pós-quântica hoje — o histórico da política de compliance — com um STARK baseado em hash, verificado dentro de um contrato Soroban.

1 O problema, com precisão

Um pagamento privado numa *privacy pool* esconde valor e contraparte. Para uma instituição isso é condição necessária, não suficiente. Faltam três coisas, e é a combinação delas que trava a migração:

1. **A política de compliance é esquecida pela rede.** A carteira reconstrói estado relendo todos os eventos que a *pool* já emitiu; o Soroban RPC guarda apenas ≈ 7 dias desses eventos (janela medida: 120.959 ledgers $\approx 7,01$ dias, que ainda *desliza* com a cadeia). O histórico das raízes de compliance — o *association set* que um provedor (ASP) publica — some da RPC durante um fim de semana. Sem esse histórico, ninguém prova, depois, que a política era íntegra.
2. **A lacuna já tem um remédio oficial — inseguro.** O cliente SPP da Nethermind já faz *handoff* para um `bootnode_url` quando bate no buraco de retenção (`sdk/client/src/sync.rs`). E a documentação da própria Nethermind (`docs/src/bootnode.md`) **nomeia** *forged-history*, *selective-omission* e *misleading-handoff* como riscos *não* mitigados — a única mitigação oferecida é “cruze com múltiplos provedores de RPC”, que é confiança social, não prova.
3. **A prova de honestidade é quebrável por Shor.** Mesmo com o histórico preservado, atestá-lo com Groth16/BN254 significa um *trusted setup* para confiar e um adversário quântico para sobreviver, num registro permanente. “Harvest now, forge later” vale para atestações tanto quanto para cifragem.

Uma tesouraria olha para isso e conclui, corretamente, que a privacidade da Stellar ainda não é utilizável em escala institucional. Não por falta de privacidade — por falta da camada que a torna auditável, durável e imposta.

2 A solução, concretamente

Três peças fecham exatamente essas três lacunas, e o laço fecha nos dois lados: sem prova, nenhuma política admitida; sem política admitida, nenhum gasto.

Peça	O que impõe	Custo on-chain medido
Atestação pós-quântica	prova que o histórico de raízes de compliance é uma sequência <i>append-only</i> sem lacunas (Circle-STARK baseado em hash, sem <i>trusted setup</i> , sem <i>pairing</i>)	<i>proof</i> $\approx$ 131 KB (off-chain, 62 bits quânticos)
Gate de compliance admit_root	registra uma raiz como válida on-chain só se a prova pós-quântica verificar na mesma transação	260M de 400M instruções (65% do teto), wasm 115 KB, $\approx$ 0,0385 XLM
Pool com política spend	liquida um pagamento confidencial só contra uma raiz admitida (<i>cross-contract is_attested</i>)	recibo on-chain, <i>replay</i> recusado

Recibos vivos na testnet (clicáveis no repositório): a raiz é admitida na transação `a2c3227c...`, o gasto liquida contra ela na `255db58d...`, e uma prova adulterada ou raiz não-admitida é **recusada on-chain**. Nada é mockado: cada número sai de um comando do próprio repositório.

O diferencial técnico contra o estado da arte é estreito e verificável: todo verificador de conhecimento zero on-chain na Stellar hoje é *pairing-based* (Groth16, UltraHonk, RISC Zero via seu embrulho Groth16). Este é — até onde a busca pública alcança — o primeiro STARK **transparente, baseado em hash**, verificado **nativamente** num contrato Soroban e tornado *load-bearing* numa política de compliance. Contra um adversário quântico ele apenas *enfraquece* (Grover corta os bits pela metade); nunca *quebra* (Shor). É a diferença entre “enfraquecido, some mais consultas” e “quebrado, comece de novo”.

3 Por que isto destrava migração de capital

O argumento causal, sem retórica:

- Uma instituição só move capital para um trilho quando os três — confidencialidade, compliance e durabilidade — estão satisfeitos **ao mesmo tempo**. Falha em um veta o conjunto.
- A Stellar entrega o primeiro com os primitivos existentes. O SPP Compliance Layer entrega os outros dois: índice durável + *bootnode* verificável (fecha o buraco de retenção e os riscos que a Nethermind documenta como abertos) e atestação pós-quântica imposta on-chain (fecha o risco de forja futura).
- Portanto o Compliance Layer não compete com as carteiras da rede — **é aquilo de que elas dependem**. Cada carteira aponta seu `bootnode_url` para cá e passa a *gatear* compliance na mesma atestação pós-quântica.

Posicionamento, com disciplina. Isto não é uma custódia nem um trilho de liquidação com garantia de recuperação de fundos. É a camada de *prova de integridade da política* sobre a qual uma custódia pode se apoiar. Torna a privacidade da Stellar auditável e durável; não guarda o ativo nem assume obrigação de VASP. Esse enquadramento é o que sustenta a conversa com um jurídico institucional.

4 Por que Stellar, e não Ethereum ou Solana

Um argumento de plataforma, com número, não com torcida:

- O mesmo relacionamento criptográfico já rodou nas três redes. Em Solana a parede foi o *heap* de 256 KB (2,38M CU em LiteSVM). Na Stellar a memória pica em 2,1 MB de 40 MB e a parede de CPU caiu para 62% do teto de uma transação, **sem mudança de protocolo** — só uma *host-function* de keccak que já existe e uma *flag* de compilador.
- O que no Ethereum L1 exigiu um verificador Solidity dedicado e anos de engenharia de uma empresa feita para isso, aqui roda como um contrato wasm comum de ≈ 115 KB que qualquer um implanta, em uma transação, por ≈ 2 centavos de dólar.
- Ou seja: a Stellar tem, hoje e sem *fork*, o *headroom* para carregar criptografia pós-quântica pesada dentro dos limites de uma transação. Esse é um argumento concreto para trazer a migração *para cá*.

5 Mercado: a dor tem dono, e tem número

O valor de RWA tokenizado on-chain (ex-stablecoins) saiu de $\approx$ US\$ 6 bi no início de 2025 para **US\$ 33,5 bi** em julho de 2026 (rwa.xyz, via Stobox), um crescimento de $\approx 4\text{--}5\times$ em dezoito meses; tesouros tokenizados são $\approx 2/3$ do setor. As projeções para 2030 vão de US\$ 2 tri (McKinsey, base conservadora) a US\$ 16 tri (BCG) — um intervalo de $8\times$ entre analistas sérios, em que a direção é consenso e só a inclinação é disputada.

A Stellar não está de fora dessa corrida: é a **quarta maior rede de RWA, com 9,0%** do valor on-chain (Stobox, jul/2026), atrás de Ethereum, BNB e Solana; foi na Stellar que a Franklin Templeton lançou seu fundo on-chain (BENJI). O capital já está chegando — e a próxima leva depende de infraestrutura, não de mais permissão regulatória.

Porque o gargalo declarado, por quem move o dinheiro, é privacidade e compliance:

Fonte	O que diz
Visa, jun/2026	“Many banks see the lack of privacy as a dealbreaker for moving meaningful activity onchain.” (Rubail Birwadker, Global Head of Growth Products)
DRW, mar/2026	Publicar toda operação on-chain seria “a failure of fiduciary duty”; “privacy is kind of at the top of the list” para adoção institucional. (Don Wilson, CEO)
EEA Privacy WG	“Privacy and confidentiality are not features — they are prerequisites for enterprise adoption.”
Fireblocks, abr/2026	O que falta é “the compliance layer alongside the privacy layer, which is where most implementations fall short.”

E o diagnóstico de infraestrutura é explícito: relatórios de 2026 (BitMart, RedStone) apontam que “*the deployment gap is an infrastructure problem, not a regulatory one*” — de $\approx$ US\$ 27 bi em RWA tokenizado, apenas $\approx 10\%$ é ativamente utilizável; os outros $\approx 90\%$ ficam parados em carteiras, rendendo mas sem circular.

A leitura de mercado converge para uma frase: falta a **camada de compliance ao lado da camada de privacidade**. É exatamente o que este projeto é — com uma diferença que ninguém mais no setor está entregando: a atestação de compliance é **pós-quântica e imposta on-chain**, não pairing-based.

Contexto competitivo, sem ilusão

Parte do capital institucional escolhe redes permissionadas (Canton, com a Visa como *Super Validator*; o Kinexys do JPMorgan liquida US\$ 7 bi/dia). O SPP Compliance Layer não disputa esse segmento fechado. Ele atende o capital que escolhe trilhos **confidenciais em cadeia pública** — o campo que Visa, Chainlink (Privacy Standard, prova de compliance on-chain) e Fireblocks estão correndo para equipar, e onde a Stellar já tem 9% do RWA. A aposta é estreita e explícita: nesse campo, ser pós-quântico e nativo do Soroban é uma vantagem que os concorrentes pairing-based não têm.

6 Público-alvo

- **Emissores de RWA e ativos tokenizados regulados** — precisam de allow-list imposta e de trilha de auditoria que sobreviva à vida longa do ativo.
- **Tesourarias e mesas de OTC/B2B** — pagamento confidencial entre partes com política de identidade, sem expor posição ao mercado.
- **Custodiantes e provedores de compliance (ASPs)** — operam a política; o Compliance Layer dá a eles uma atestação que um regulador aceita como prova, não como promessa.
- **Reguladores e auditores** — o consumidor final da atestação: verificam a integridade de um conjunto de aprovação de 2026 em 2035, mesmo depois que um quântico poderia forjar um BN254.

O gancho comum a todos: precisam de privacidade *do mercado*, não do regulador — confidencialidade seletiva com trilha de auditoria — e precisam que essa trilha sobreviva à vida longa do ativo. É o par exato que a seção de mercado documenta como o gargalo aberto.

7 Como monetiza

Três linhas de receita, em ordem de proximidade:

1. **Bootnode verificável como serviço.** Operar o *bootnode* confiável que os clientes SPP apontam, com SLA e prova de cobertura. Assinatura por instituição.
2. **Atestação como serviço.** Cobrar por atestação pós-quântica de histórico de compliance (por período/por *pool*) para ASPs, emissores e custodiantes que precisam da prova para relatório regulatório.
3. **Licenciamento do verificador on-chain + SDK.** O contrato-*gate* e o SDK de integração para quem quer *gatear* liquidação na própria política.

O primeiro marco de negócio é uma integração real — um piloto com um ASP, emissor ou custodiante — não um preço de tabela.

8 Roadmap

- **Agora:** testnet, laço completo provado (*gate + pool*), recibos vivos, dupla submissão no Stellar Summit (raia *Wallets* e raia *Enterprise/Compliance/RWA*).
- **Curto prazo:** elevar a segurança quântica on-chain de 24 bits (no orçamento de uma transação, 40 consultas) via camada recursiva — a técnica STARKPack do próprio patrocinador — a custo limitado. Off-chain já são 62 bits.

- **Médio prazo:** *deploy* em mainnet (os limites de mainnet foram lidos de `getLedgerEntries` e todos os números cabem identicamente — é decisão de *funding*, não de engenharia). Primeira integração com um ASP/emissor real.
- **Longo prazo:** *wiring* da *pool* para *exigir* a atestação como pré-condição de liquidação.

9 Considerações de implementação

Ditas na frente, porque é o que sustenta credibilidade técnica — cada uma com seu endereçamento:

- **A atestação prova estrutura de índice, não legitimidade de raiz.** Ela prova que o histórico é uma sequência *append-only* sem lacunas sobre raízes testemunhadas, com *end-points* fixados em valores públicos — legíveis on-chain. A ligação de *completude* é a prova de cobertura da camada de índice. As duas juntas dão a garantia; declaradas com precisão, não infladas.
- **24 bits quânticos on-chain** no orçamento de uma transação, contra 62 off-chain. O caminho recursivo (STARKPack) é o plano de escala para elevar a cifra on-chain a custo limitado.
- **Testnet, com caminho de mainnet medido.** Os limites de mainnet já foram lidos e todos os números cabem; o *deploy* é decisão de *funding*.
- **Enquadramento jurídico.** O posicionamento correto — camada de prova de integridade, não custódia — mantém o produto fora da obrigação de VASP e é sustentado com disciplina em todo material externo.

Fecho

A Stellar já tem privacidade. O que falta para ela receber capital institucional não é mais privacidade — é a camada que torna essa privacidade auditável por um regulador e durável através da transição quântica, imposta pelo próprio livro-razão. Essa camada existe, roda na testnet com recibos, e é honesta sobre onde para. O trabalho de negócio a partir daqui é uma coisa só: converter uma prova técnica que funciona em uma integração institucional que paga.

Repositório: github.com/Galmanus/spp-compliance-layer · MIT · recibos e verificação independente em `VERIFY-IT-YOURSELF.md`

Fontes de mercado

- Stobox, *State of RWA Tokenization — 2026 Mid-Year Report*, jul/2026 (US\$ 33,5 bi on-chain; Stellar 9,0%). stobox.io/reports/state-of-rwa-2026
- CoinGecko, *RWA Report 2026* (US\$ 5,42 bi → US\$ 19,3 bi, +256,7%). [coingecko.com](https://www.coingecko.com)
- BitMart / RedStone, *State of RWA*, mai/2026 (US\$ 24,6 bi TVL; “infrastructure problem, not regulatory”; ≈10% composável). bitmart.com
- Chainalysis, *Tokenized RWAs*, abr/2026 (≈US\$ 30 bi AUM; capital institucional supera o de varejo).
- Visa / FinTech Magazine, jun/2026 (“lack of privacy as a dealbreaker”). fintechmagazine.com
- CoinDesk, *DRW’s Don Wilson on open ledgers*, mar/2026 (“failure of fiduciary duty”). coindesk.com
- Fireblocks (Ran Goldi), *The Blockchain Privacy Problem*, abr/2026 (“compliance layer alongside the privacy layer”). fireblocks.com
- Enterprise Ethereum Alliance, *State of Privacy on Ethereum for Enterprise* (“prerequisites for enterprise adoption”).
- Projeções 2030: McKinsey (US\$ 2 tri, base) e BCG (US\$ 16 tri).